# Digital Health Record Management System (DHRMS)

**LAB 7: System Architecture Diagram — Multi-Tier Topology, Service Decomposition & Security Infrastructure**

**Course:** Software Engineering (SWE) Academic Session 2026–2027 | **Faculty Guide:** Mr. Navdesh Singh, Dept. of CSE | **Baseline:** DHRMS SRS v2.0 (ISO/IEC/IEEE 29148) & TBD Resolutions

## 1. Architectural Scope & Quality Attribute Drivers

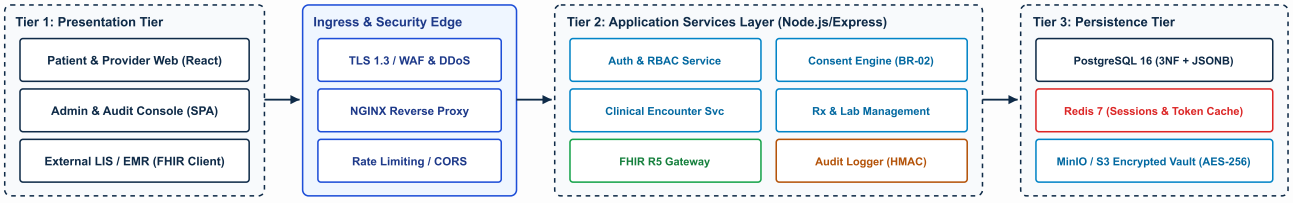
LAB DELIVERABLE 7

The objective of this laboratory is to establish the formal System Architecture for DHRMS based on SRS Section 2.1, Section 5, and the 15 architectural engineering resolutions (TBD-001 through TBD-015). The architecture adopts a **3-Tier Micro-Modular Architecture** (TBD-015) providing high availability (99.9%, TBD-013), low response latency (p95 ≤ 1.8s, REQ-PERF-003), strict HIPAA compliance, and secure HL7 FHIR Release 5 interoperability.

> **Architectural Invariant & Zero-Trust Boundaries:** All inbound traffic terminates at a hardened reverse proxy with TLS 1.3 encryption (HSTS max-age=31536000). Application services authenticate requests via short-lived JWTs and dynamic consent directives, while administrative operations are strictly isolated from clinical Protected Health Information (PHI) tables (BR-04).

## 2. High-Level Multi-Tier System Architecture Diagram

ARCHITECTURE TOPOLOGY




**Tier Separation Invariants:**

- **Client Isolation:** React SPA interacts solely through HTTPS JSON APIs; no direct DB connections.
- **Stateless Micro-Modules:** Services scale horizontally; session states reside in Redis 7 (TTL 15 mins).

**Asynchronous Reliability:**

- **Non-Blocking Audit:** Security & PHI operations dispatch audit logs via decoupled event streaming.
- **Binary Offloading:** Clinical documents > 1 MB stream directly to MinIO/S3 using pre-signed URLs.

## 3. Component Specifications & Subsystem Decomposition

ARCHITECTURE MODULES

In accordance with SRS Section 2.1 and Section 4.1–4.10, the system decomposes into seven autonomous components. Each component maintains distinct execution boundaries, interface contracts, and access privileges:

| Component Name | Runtime & Tech Stack | Core Responsibilities & Capabilities | Security & Invariants |
|---|---|---|---|
| **Ingress & API Gateway** | NGINX / Express Gateway (Node.js 20 LTS) | Reverse proxy, TLS 1.3 termination, rate limiting (100 req/min/IP), CORS filtering, request routing. | Blocks unauthenticated requests; enforces HSTS & OWASP ASVS headers. |
| **Identity & Auth Service** | Node.js / Argon2id / RFC 6238 TOTP | User authentication, password hashing, MFA verification, JWT issuance (15-min expiry), account locking. | Salted Argon2id hashing; account locked after 5 failed login attempts. |
| **Consent Engine** | Node.js Service / Redis Cache | Evaluates patient consent directives against provider queries (UC-03); validates scope and expiry dynamically. | Zero-trust evaluation; immediately blocks revoked directives (BR-03). |
| **Clinical Core Service** | Node.js / Express / TypeScript | Longitudinal EHR aggregation, consultation charting (SOAP format), e-prescriptions, and LOINC diagnostics. | Strictly checks active consent before materializing clinical records. |
| **FHIR Interoperability Gateway** | HL7 FHIR R5 Adapter / JSON-Schema | Exchanges Patient, Encounter, and Observation resources with external hospital systems and LIS (UC-10). | Mutual TLS (mTLS) or OAuth2 Bearer; payload sanitation prior to DB write. |
| **Document Object Vault** | MinIO / AWS S3 API SDK | Stores binary medical scans, lab PDFs, and DICOM images (up to 25 MB per stream, TBD-012). | AES-256 server-side encryption; SHA-256 integrity verification. |
| **Immutable Audit Service** | Node.js / Cryptographic Hash Engine | Captures chronological security and PHI access logs; builds tamper-evident HMAC audit hash chains. | Write-once append-only; protected against modification or deletion (BR-04). |

## 4. Inter-Component Communication Protocols & Data Flow Contracts

INTERFACE CONTRACTS

Communication between architectural tiers follows strictly governed protocols to eliminate single points of compromise and minimize operational latency across distributed container nodes:

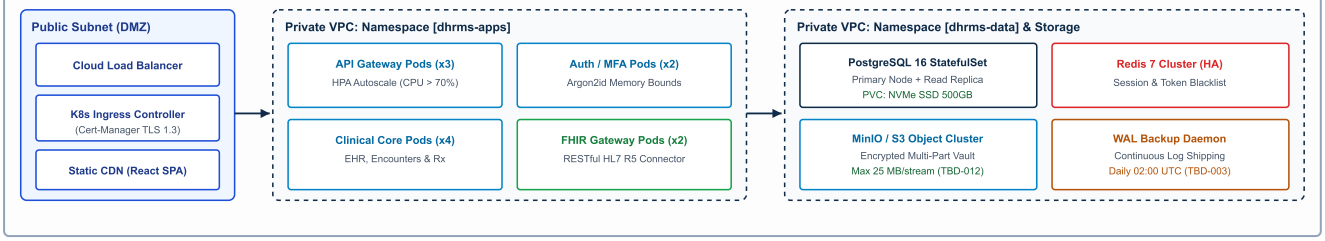
- **External Edge Protocols:** Clients communicate exclusively via HTTPS `(TLS 1.3/1.2)` over port 443 with enforced HTTP/2 multiplexing. Payloads are strictly UTF-8 encoded JSON conforming to RFC 7807 error formatting.
- **Internal Micro-Service Mesh:** Internal inter-pod communications utilize private virtual network interfaces (Kubernetes overlay network) secured with internal mutual TLS (mTLS) and short-lived signed tokens.
- **Database Connection Pooling:** Relational queries execute over encrypted PostgreSQL wire protocol (Port 5432) using persistent connection pools (PgBouncer) configured with a ceiling of 200 dedicated connections.
- **Document Streaming:** Client document uploads bypass the application runtime heap: the API Gateway generates pre-signed S3 upload URLs, permitting direct browser-to-storage binary streaming with SHA-256 validation.

> **Separation of Administrative Duties:** As required by Business Rule BR-04, the Database Connection Pool allocates segregated user accounts. The administrative microservice connects using a credential role with permissions revoked from clinical health tables.

## 5. Deployment Architecture: Kubernetes Container Orchestration (TBD-002)

DEPLOYMENT DIAGRAM

DHRMS is deployed across containerized Linux environments (Alpine / Ubuntu 22.04 LTS) orchestrated via Kubernetes. The cluster isolates workloads into distinct security namespaces with automated Horizontal Pod Autoscaling (HPA):




## 6. High Availability, Autoscaling & Operational Sizing

SIZING & TELEMETRY

The container cluster is sized to sustain hospital operations under nominal and surge conditions (TBD-011):

- **Capacity Baseline:** Sized for **500 active concurrent users** with dynamic auto-scaling bursting to **2,500 concurrent sessions** without degradation of the 2.0s page render SLA (REQ-PERF-001).
- **Autoscaling Policy:** The Horizontal Pod Autoscaler (HPA) monitors CPU (> 70%) and Memory (> 75%) thresholds, spinning up replacement pods in ≤ 12 seconds using pre-warmed container images.
- **Disaster Recovery Standards:** Complies with **RPO ≤ 1.0 hour** (TBD-004) and **RTO ≤ 4.0 hours** (TBD-005) via automated PostgreSQL Write-Ahead-Log (WAL) shipping to off-site cloud storage.

> **Storage Persistence & 3NF Relational Structure:** PostgreSQL 16 operates in Third Normal Form (3NF) with referential integrity. Diagnostic reports and FHIR resources utilize indexed JSONB columns with Generalized Inverted Indexes (GIN) for sub-second search.

## 7. Defense-in-Depth Security Architecture (OWASP ASVS & HIPAA)

SECURITY BLUEPRINT

DHRMS enforces a comprehensive four-tier defense-in-depth model aligned with OWASP ASVS 5.0 Level 2 and HIPAA security benchmarks (SRS Section 5.3):

**Perimeter & Network Security:**

- WAF deep packet inspection blocks SQLi and XSS.
- Enforced TLS 1.3 / HSTS eliminates downgrade vectors.
- Virtual Private Cloud (VPC) isolates data pods from the internet.

**Cryptographic & Storage Controls:**

- Passwords hashed with salted **Argon2id** (REQ-SEC-004).
- PostgreSQL tablespaces encrypted with **AES-256 KMS**.
- Audit trails write to an append-only, tamper-evident hash ledger.

## 8. Architectural Traceability Matrix (Requirements & TBDs to Architecture)

TRACEABILITY MATRIX

| SRS / TBD Baseline | Target Architectural Benchmark | Realizing Component / Node | Verification Strategy |
|---|---|---|---|
| **TBD-001, TBD-006** | PostgreSQL 16 Engine; 7-Yr Clinical Retention | `PostgreSQL StatefulSet` (Namespace: `dhrms-data`) | ACID Transaction & Retention Testing |
| **TBD-002, TBD-011** | K8s Deployment; 500–2,500 Concurrent Users | `HPA Cluster Nodes` + Cloud Load Balancer | Load & Stress Testing (≥ 150% peak) |
| **TBD-004, TBD-005** | RPO ≤ 1.0 Hour; RTO ≤ 4.0 Hours | `WAL Archiving Daemon` + Off-site Cloud Sync | Disaster Recovery Simulation Drill |
| **TBD-008, REQ-AUTH** | TOTP (RFC 6238) MFA + Argon2id Hashing | `AuthService` + `Redis Session Store` | OWASP Penetration & Security Audit |
| **TBD-010, REQ-INT** | HL7 FHIR Release 5 RESTful Interchange | `FHIR Gateway Pods` (mTLS / OAuth2) | FHIR Validator Suite & Schema Tests |
| **TBD-012, REQ-DOC** | 25.0 MB Clinical Document Uploads | `MinIO / S3 Object Vault` (AES-256) | Pre-signed URL Stream Benchmarking |

## 9. Faculty Guide Evaluation & Supervisory Sign-Off Block

EVALUATION

**Faculty Guide Evaluation Remarks:**

The System Architecture specifications, 3-tier decomposition, Kubernetes container orchestration model, and defense-in-depth security topology strictly conform to ISO/IEC/IEEE 29148 standards and the DHRMS Version 2.0 engineering baseline. All 15 TBD architectural parameters are rigorously accounted for.

**Status:** APPROVED **Lab Grade:** _____ / 10

**Faculty Supervisor:**
Mr. Navdesh Singh
Dept. of Computer Science & Engg.

---

Faculty Signature & Date

Prepared by: Abhinav Singh (202401100200014), Abhinav Pathak (202401100200013), Abhishek Kumar Verma (202401100200015), Abhishek Yadav (202401100200016)